No Edges, No Verdict: A Large-Scale Empirical Study of Declared Dependency Graphs in 78K SBOMs in the Wild

Artur Zięba-Kozarzewski
0000-0003-4696-4983
KRYPTON Polska Sp. z o.o.
Warszawa, Poland
Email: a.zieba@krypton-polska.com

arXiv:2607.22140v3 [cs.SE] 22 Oct 2026

***Abstract*—Software Bills of Materials (SBOMs) are consumed not only as component inventories but as *dependency graphs*: vulnerability triage, reachability filtering, and impact analysis all traverse the edges an SBOM declares. We present the first large-scale characterization of the *declared* dependency graph across 78,612 real-world SBOM files from the Wild SBOMs dataset (77,092 parseable). We find that the population splits into three regimes: 52.9% of SBOMs declare *no edges at all* (failing the NTIA minimum-elements requirement of dependency relationships; 42.3% once the 46.5% of files carrying the tool entry of a single generation harness are set aside), 8.8% declare a dependency block yet leave the majority of components isolated (*degenerate* regime; among such SBOMs with at least 50 components the median orphan share is 93%, and our 11 Syft-generated container-image SBOMs fall in this regime at 91.4–98.0% orphans), and 38.3% form well-connected graphs. Edge emission is predicted by the *generator* rather than by the format (0%–100% no-edge rates across tools), and the specification-level mechanism for declaring graph incompleteness (CycloneDX `compositions`) is used by 0.10% of CycloneDX documents. We argue that in the first two regimes, the common consumer inference *no path* $\Rightarrow$ *unreachable* is an unsound closed-world conclusion drawn from a demonstrably incomplete artifact; in a production vulnerability-prioritization system, replacing the resulting veto with an explicit *unknown* level guarded by a degeneracy detector recovered KEV recall from 0.600 to 0.950 (controlled re-scoring; 0.957 in a live end-to-end run) without alert flooding. The streaming scanner and the full per-SBOM topology dataset are archived on Zenodo.**

I. Introduction

SBOMs promise transparency for the software supply chain, and a growing tool ecosystem consumes them for vulnerability management. Several of the highest-value consumption scenarios read the SBOM as a *graph*: which components does the application actually pull in, through which paths, and is a vulnerable component reachable from the artifact's roots? The NTIA minimum elements make this explicit: *dependency relationships* are a required field, not an optional enrichment [1].

This paper asks a question that, to our knowledge, no prior work has asked at population scale: **what does the graph that SBOMs actually declare look like?** Prior large-scale studies audited SBOM *fields* (standards adherence, license accuracy, inter-tool consistency [2]) or the gap between filesystem contents and metadata [3], but none measured the topology of the declared dependency graph itself; the one study that did measure it did so on 119 documents [4]. Software Dark Matter [3] recently exposed one axis of SBOM deficiency: files present in the artifact but absent from its metadata ("what the SBOM does not declare at all"). We study the orthogonal axis: *what the SBOM declares, but without edges*. Both axes break the same implicit consumer assumption that SBOM silence is evidence of absence.

Scanning all 78,612 SBOMs of the Wild SBOMs corpus [5] with a streaming analyzer, we find the declared graph is missing far more often than the literature assumes. 52.9% of parseable SBOMs carry *no dependency information whatsoever* (NO_EDGES): every component is trivially isolated because the generator emitted a flat inventory. Close to half of the corpus comes from one automated generation harness; without it the share is 42.3% (Section IV). Among the 36,336 SBOMs that do declare a dependency block, the orphan ratio (share of fully isolated components) is strongly bimodal: a *connected* mode (54.7% below 0.1), a *degenerate* mode (15.4% at or above 0.9), and an almost empty valley in between (2.8% in 0.5–0.8); the degenerate class as a whole (orphan ratio above 0.5) covers 18.7% of this subset, i.e., 8.8% of the population. The pattern is not small-sample noise: restricted to SBOMs with at least 50 components the modes sharpen (76.8% vs. 5.7%, valley 1.8%), and the median orphan share of the large degenerate SBOMs is 0.93. Syft-generated SBOMs of large production container images sit squarely in this large-degenerate mode: across 11 images we measured 91.4–98.0% orphans at edge densities of $E/V \in [0.026, 0.229]$ (Section V).

We structure the study around five questions:

- **RQ1** What dependency graph do published SBOMs actually declare, and how does the population divide into regimes (taxonomy; NTIA field-5 compliance)?
- **RQ2** What predicts the regime — format, generating tool, or ecosystem of the described software?
- **RQ3** Do specification-level completeness declarations and field-quality scores surface the graph's absence to a consumer?
- **RQ4** What does the closed-world reading of these graphs

cost in a production vulnerability-prioritization pipeline?

- **RQ5** Does an open-world semantics recover that cost without breaking alert-volume guardrails?

RQ1–RQ3 are answered population-wide in Section IV; RQ4–RQ5 on our production testbed in Section VI, with generalization beyond the testbed left to follow-up experiments.

These are not benign bookkeeping gaps. A consumer that treats the declared graph as complete (a *closed-world* reading) will conclude that an isolated component is unreachable and deprioritize its vulnerabilities. We show how a multi-signal prioritization pipeline came to miss 8 of 20 KEV-listed (known-exploited) vulnerability instances in container workloads; 7 of the 8 were lost through this veto alone, including Log4Shell (Section VI). The closed-world reading is unsound because SBOM extractors are *soundy* in a precise, asymmetric way: a declared edge is (almost always) a true dependency, but a missing edge is not evidence of independence [6], [7]. The specification even provides an explicit escape hatch: CycloneDX `compositions` lets producers declare graph (in)completeness [8]. Yet we find it used by 59 of 61,691 CycloneDX SBOMs in the wild (0.10%).

Contributions.

- **C1 — population characterization.** The first topology census of declared dependency graphs at scale (78,612 SBOMs), with a three-way taxonomy (NO_EDGES / *degenerate-with-edges* / *connected*), NTIA field-5 compliance measured population-wide (52.9% non-compliant; 42.3% without the dominant generation harness), breakdowns by format, generator, and ecosystem showing that edge emission is predicted by the toolchain rather than the format, and usage of spec-level completeness declarations (0.10% of CycloneDX documents).
- **C2 — semantics.** An open-world reading of declared graphs: the asymmetric soundness argument, an *unknown* reachability level distinct from evidence-based *unreachable*, and a graph-degeneracy detector (orphan ratio > 0.5) deciding when the veto semantics is invalid.
- **C3 — validated consequence.** In a production prioritization system, the open-world semantics recovered KEV recall (measured with the KEV flag removed from scoring; EPSS, which itself encodes catalogue information, is retained) $0.600 \rightarrow 0.950$ (controlled offline) and 0.957 (live, full pipeline; 1.000 with the KEV signal restored) with volume guardrail intact (flooding $12.1\% < 15\%$). Generalization of this effect beyond our testbed, and the complementary value of the veto in the connected regime, are the subject of ongoing experiments (Section VI, "Future work").
- **C4 — artifact.** A streaming scanner (no decompression of the 5 GB corpus), the full per-SBOM topology dataset, and the 11-image container corpus, archived on Zenodo (Section IX).

II. Background and Motivation

SBOMs are mandated, and the graph is part of the mandate. Executive Order 14028 made SBOMs a procurement expectation for software sold to the US federal government [9]; the EU Cyber Resilience Act extends machine-readable component transparency to products with digital elements in the EU market [10]. The operative definition in both ecosystems descends from NTIA's *minimum elements*, whose baseline fields include *dependency relationships* [1], and CISA's follow-up framing keeps relationships in the baseline [11]. An SBOM without edges thus lacks a required baseline element; we measure below how often that is the case.

Consumers read the graph, not just the list. The scenarios that motivate SBOM adoption are graph traversals. Vulnerability triage pipelines [12] combine severity and exploitation signals (CVSS, EPSS [13], CISA KEV) whose disagreements are well documented [14], [15], and then contextualize them with *structure*: is the vulnerable component reachable from the application, how central is it, what is the blast radius [16]. Impact and propagation studies in Maven quantify how vulnerabilities travel along dependency edges [17], [18], [19], [20]; counting *actually* vulnerable dependencies, as opposed to inflated flat counts, requires knowing which dependencies are real and how they connect [21], [22]. Supply-chain attack taxonomies likewise assume transitive visibility: the attacks exploit exactly the paths that flat inventories do not show [23], [24], [25]. Every one of these consumers presupposes that the SBOM's edge set approximates the truth. This paper measures how often that assumption has any data behind it.

III. Dataset and Method

Corpora. Our primary corpus is Wild SBOMs [5]: 78,612 unique SBOM files mined from Software Heritage (1,782 forges), i.e., SBOMs *as they exist in public code*, checked into repositories by their producers. One producer dominates: 36,551 files (46.5%) carry the same tool entry, Fortress Information Security's `Github Extractor` 1.15.1, alongside up to six other tools, and an independent second measurement traced them to a single automated generation harness that ran several SBOM generators over public repositories in 2022 [26]. We report headline shares with and without it. Provenance metadata (format, standard, sbomqs quality score, filenames) accompanies each file. Our secondary corpus comprises 11 container SBOMs we generated with Syft 1.42.3/1.42.4 [27] from large production images (ML/AI, CI, data science, monitoring; 5,263–87,776 components), the consumer-side scenario in which we first observed the phenomenon.

Measures. For each SBOM we stream-parse CycloneDX (JSON) or SPDX (JSON) and build the declared graph: nodes are components (`bom-ref` / `SPDXID`), edges are declared dependency relations (`dependencies[].dependsOn`; `DEPENDS_ON`/`CONTAINS` relationships). We record V, E, E/V, orphan ratio (degree-0 share), connected components, format, generator (from metadata tools/creators, cross-checked against filenames), dominant purl ecosystem, purl/version/scope coverage, and the CycloneDX `compositions` completeness declaration. The scanner streams the 5 GB zstd-compressed archive in a single pass (no

extraction to disk), persists one CSV row per file with per-row fsync, and resumes idempotently after interruption; a full-population scan takes under ten minutes on commodity hardware, which makes exact (non-sampled) population statistics practical. We additionally join each SBOM to its sbomqs [28] field-quality score shipped with the corpus metadata.

The scanner and the downstream statistical scripts were implemented with the assistance of a generative-AI coding tool (see the AI declaration); we treat them as we would any software instrument and validate accordingly. The pipeline is deterministic, and two independent full scans run three months apart, on different scanner revisions, produced bit-identical V and orphan ratios for all 77,092 parseable SBOMs (Section IV); all released code is open for inspection (Section IX).

Taxonomy. Formally, let $G(S) = (V, E)$ be the directed graph declared by SBOM S. We define the *orphan ratio*

$$\rho(S) \;=\; \frac{|\{\, v \in V : \deg_G(v) = 0 \,\}|}{|V|}, \tag{1}$$

and classify S by whether it declares a dependency block (D: a `dependencies` array or a dependency-relationship list) and by ρ:

$$\mathrm{class}(S) = \begin{cases} \text{NO_EDGES} & \neg D, \\ \text{degenerate-with-edges} & D \wedge \rho(S) > \tau, \\ \text{connected} & D \wedge \rho(S) \le \tau, \end{cases} \tag{2}$$

with $\tau = 0.5$; the classification is insensitive to this choice (Section IV). The discriminator is the presence of the block, not the edge count: 4,855 of the 36,336 block-declaring SBOMs (13.4%) carry a block that yields no usable edge (entries without resolvable `dependsOn` targets) and sit at $\rho = 1$, the degenerate extreme. A block-less document, by contrast, is not treated as the $\rho = 1$ limit, and we report distributions separately per class: a missing block is a format-level omission, and folding it into the orphan-ratio distribution would overstate the degenerate mode (the distribution over the block-declaring subset is shown in Fig. 1, Section IV).

Threats. (i) Wild SBOMs are repository-committed artifacts, not build-fresh outputs; they reflect what producers publish, which is the consumer-visible population, but may lag generator versions and underrepresent consumer-side image scans (see Section V). (ii) Our earlier pilot sampled the archive head (first-N); the full scan removes sampling entirely, and an offset-sample sanity test showed distribution stability (modes 42/58 vs. 41/59). (iii) Generator attribution and the container flag depend on self-reported metadata and filename heuristics; we report the unknown share and treat those breakdowns as descriptive. Attribution keys on the first tool listed, and near-identical strings can denote different tools: `Github Extractor` is Fortress Information Security's tool, whereas GitHub's own dependency-graph exporter (`GitHub.com-Dependency-Graph`) appears in only 17 documents, 16 of them with edges. (vi) The harness above makes the corpus less independent than its size suggests; every population share is therefore also given without it. (iv) 1.9% of files fail to parse (unrecognized formats); their exclusion is format-level, not topology-correlated, although 735 of the 1,520 failures carry the harness's tool entry. (v) Small SBOMs dominate the degenerate class by count (median $V = 3$); we therefore report the $V \ge 50$ restriction alongside the full distribution, and the bimodal structure persists in both.

TABLE I
DECLARED-GRAPH TAXONOMY OVER 77,092 PARSEABLE SBOMS.

Class	n	share	med. V	med. E/V
NO_EDGES	40,756	52.9%	16	0.000
degenerate-with-edges	6,796	8.8%	3	0.000
connected	29,540	38.3%	49	0.995

IV. RESULTS I: THE POPULATION

Taxonomy. Of 78,612 files, 77,092 (98.1%) parse as CycloneDX (80%) or SPDX (20%); the 1,520 failures are format-level (unrecognized or non-JSON documents) with no error class suggesting systematic bias. Table I shows the three-way split. Read as NTIA compliance: **52.9% of published SBOMs omit the required dependency-relationships field entirely**; without the generation harness of Section III ($n = 40{,}541$) the three shares are 42.3%, 11.4% and 46.3%.

Cross-format. NO_EDGES is not an artifact of one standard: 53.7% of CycloneDX and 49.5% of SPDX documents lack the block (37.9% of CycloneDX documents without the harness, which emits CycloneDX only). The driver sits one level deeper, in the generating tool.

The generator predicts the graph; the format does not. No-edge rates span the full range across generators (Table II): Fortress Information Security's `Github Extractor`, which despite its name is not GitHub's dependency-graph exporter, never emits edges (100%); Gemnasium (94.3%), Node.js module metadata (87.1%), and Syft (82.6%) rarely do, while lockfile-based tools (`cyclonedx-gomod`, 0.0%; `cyclonedx-php-composer`, 0.2%) and Microsoft's generator (0.4%) almost always emit a graph. Edge emission is thus predicted by the *toolchain* far better than by the format: two SBOMs of the same project, produced by different mainstream tools, can land in opposite regimes, and the consumer cannot tell which regime they are in from the document alone.

One harness, nearly half the corpus. The 36,551 harness documents (Section III) are 64.6% NO_EDGES, 5.9% degenerate and 29.4% connected; the remaining 40,541 are 42.3%, 11.4% and 46.3%. The generator finding survives the exclusion: outside the harness, no-edge rates still run from 0.0% (`cyclonedx-gomod`, $n = 857$) to 100.0% (two generators with over 1,700 documents each). The rows of Table II are keyed on the first tool listed, however, and in harness documents that tool need not be the one that shaped the output: all 9,742 harness documents listing `cdxgen` first also list the Fortress tool, and none of them has a block, whereas `cdxgen` documents outside the harness omit it in 18.1% of cases ($n = 7{,}735$; 63.7% over all its documents). The rows therefore describe toolchains rather than single tools.

TABLE II
REGIME SHARES BY GENERATOR (TOP ATTRIBUTED TOOLS BY VOLUME, KEYED ON THE FIRST TOOL LISTED; UNATTRIBUTED DOCUMENTS, $n = 2{,}073$, OMITTED). GITHUB EXTRACTOR IS FORTRESS INFORMATION SECURITY'S TOOL, NOT GITHUB'S EXPORTER. ALL OF ITS DOCUMENTS, AND 56–96% OF THE CDXGEN, NODE.JS MODULE, CYCLONEDX-GOMOD AND CDX-PHP-COMPOSER ROWS, COME FROM ONE GENERATION HARNESS.

Generator	n	NO_EDGES	degen.	conn.
cdxgen	17,477	63.7%	6.1%	30.2%
Node.js module	10,320	87.1%	5.4%	7.5%
cyclonedx-gomod	6,414	0.0%	11.4%	88.6%
cdx-php-composer	6,394	0.2%	12.5%	87.3%
Github Extractor	4,504	100.0%	0.0%	0.0%
Microsoft	3,334	0.4%	0.0%	99.6%
Syft	3,293	82.6%	7.1%	10.3%
Gemnasium	2,702	94.3%	0.0%	5.7%
Anchore	2,014	19.7%	1.7%	78.6%

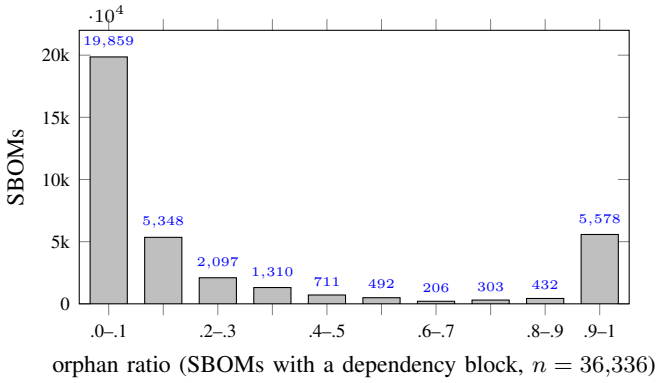

Fig. 1. Orphan-ratio distribution over the block-declaring subpopulation: a connected mode, a degenerate mode, and a near-empty valley (0.5–0.8 holds 2.8% of the mass). Bins are left-closed, $[a, a{+}0.1)$, with the last bin $[0.9, 1.0]$; the 215 SBOMs at exactly $\rho = 0.5$ fall in the 0.5–0.6 bar yet classify as *connected* under the strict $\rho > \tau$ rule, which is why the bars from 0.5 upward sum to 7,011 against a degenerate-class size of 6,796. NO_EDGES SBOMs (40,756) are excluded by construction.

Bimodality and detector threshold. On the block-declaring subset (36,336 SBOMs) the orphan-ratio distribution is bimodal: 54.7% below 0.1, 15.4% at or above 0.9, and only 2.8% in the whole 0.5–0.8 band (Fig. 1). The degenerate mode is itself composite: 4,855 of the 5,578 documents at or above 0.9 (87.0%) are the empty-block documents of Section III, sitting at $\rho = 1$ with no realized edge, and they account for 71.4% of the degenerate class (4,855 of 6,796); the remaining 1,941 class members realize at least one edge. The composition inverts with size: in the $V \geq 50$ stratum the degenerate class is dominated by documents *with* realized edges (1,370 of 1,582), so the large-degenerate phenomenon is not an artifact of empty blocks. The near-empty valley makes the degeneracy detector insensitive to its threshold: moving the cut from 0.5 to 0.6 reclassifies 302 SBOMs (0.83% of the subset), and the degenerate share drifts only from 18.7% to 17.9%. We therefore retain the production threshold of 0.5. Restricting to SBOMs with $V \geq 50$ sharpens the picture (76.8% below 0.1, 5.7% at or above 0.9, 1.8% valley; the degenerate class holds 9.7%) and places the median orphan share of large degenerate SBOMs at 0.93 (0.91 when the empty-block documents are excluded).

Ecosystem gradient. Within the block-declaring subset, degeneracy tracks the dependency-resolution style of the dominant ecosystem: SBOMs dominated by `pypi` purls are degenerate in 38.8% of cases and `npm` in 24.8%, versus 1.2–1.3% for `composer` and `deb` and 9.1% for `golang`. Manifest-style inputs without resolved lockfiles (`requirements.txt`) yield components without edges; lockfile-graph ecosystems (`composer.lock`, `go.mod`) yield connected graphs.

Completeness is almost never declared; quality scores see it only outside one harness. Only 59 of 61,691 CycloneDX SBOMs (0.10%) carry a `compositions` block, and most of those declare a mixture containing `unknown`. Corpus-wide, field-oriented quality scoring barely separates the regimes, but that figure is produced by the generation harness: the median sbomqs score of NO_EDGES SBOMs (6.40) sits within 0.1 of that of connected ones (6.50) on a ten-point scale (AUC 0.60), and inside the harness the two are equal (6.9 against 6.9; AUC 0.49). Outside it the medians are 5.7 and 6.2, and the score ranks a connected document above a NO_EDGES one with probability 0.79; the separation holds within format (0.77 for CycloneDX, 0.82 for SPDX) and within generator (0.83, weighted over the eight generators with at least 100 documents in each class), so it is not an artifact of format or tool mix. A document can still score well while carrying no graph, but outside the harness the score does respond to the missing block.

Reproducibility. Two independent full scans of the corpus, run three months apart with different scanner revisions, produced bit-identical V and orphan ratios for all 77,092 SBOMs (100.00% agreement), and identical parse/error counts.

V. RESULTS II: IMAGE-SCAN SBOMS, THE LARGE-DEGENERATE ARCHETYPE

Across 11 production images scanned with Syft (nvidia/cuda, pytorch, tensorflow, jupyter/all-spark-notebook, and GitLab CE, among others; V from 5,263 to 87,776), every SBOM landed deep in the degenerate regime: orphan share 91.4–98.0%, $E/V \in [0.026, 0.229]$, with edges concentrated in one OS-package cluster while language-level components (pip, npm, gem) remain isolated. The pattern is systematic, not image-specific: multi-ecosystem artifacts assembled by layered package managers defeat the per-manifest edge extraction that generators rely on (Table III). It also matches the population: the median orphan share of large ($V \geq 50$) degenerate SBOMs in the wild is 0.93, and 0.91 when the empty-block $\rho = 1$ documents are excluded ($n = 1{,}370$ with realized edges); our image scans are typical members of that mode, at its upper end.

A note on scope: we deliberately say *image-scan* SBOMs, not "container SBOMs in the wild." Wild SBOMs is mined from code repositories, and the 2,718 files our scanner heuristically flags as container-related there are mostly Dockerfile- or source-derived documents; only 9 of them (0.3%) are

TABLE III
THE 11-IMAGE CORPUS (SYFT 1.42.3/1.42.4 SCANS OF PRODUCTION IMAGES).

Image	V	E	E/V	orph.
gitlab/gitlab-ce:17.0	87,776	2,306	0.026	97.6%
devcontainers/universal:2	67,623	5,629	0.083	94.7%
jupyter/all-spark-notebook	41,628	2,206	0.053	97.9%
rocker/tidyverse	19,093	1,182	0.062	97.9%
catthehacker/ubuntu:act	18,371	2,732	0.149	91.5%
tensorflow:2.16.1-gpu	13,392	993	0.074	97.5%
pytorch:2.3.0-cuda12.1	11,214	781	0.070	97.1%
nvidia/cuda:12.4.0-devel	11,078	618	0.056	98.0%
continuumio/anaconda3	8,744	2,002	0.229	93.9%
apache/spark:3.5.1	6,020	649	0.108	94.3%
gitlab/gitlab-runner	5,263	686	0.130	91.4%

degenerate-with-edges. Image scans of the kind consumers produce with Syft/Trivy against running workloads are under-represented in repository-committed corpora, which is why we contribute the 11-image corpus as a separate, consumer-side artifact.

Prior container-security studies counted vulnerabilities in images at scale [29], [30]; to our knowledge none examined the structure of the dependency graph that image SBOMs declare, which is what downstream tooling actually traverses.

Two practical consequences follow. First, any graph-centrality–based component ranking must handle the isolated mass explicitly; filtering orphans before betweenness computation [31] preserved exact results while reducing runtime by 200–4000$\times$ on our corpus. Second, the isolated mass interacts with reachability semantics, which we turn to next.

VI. THE REACHABILITY TRAP

The unsound inference. Vulnerability prioritization pipelines commonly multiply a reachability factor into their score; *unreachable* acts as a veto ($\times 0$). On a declared graph this encodes the closed-world assumption [7]: from "no declared path" infer "no path." CWA is valid only against complete relations. SBOM extraction is *soundy* [6] with a specific asymmetry: declared edges are trustworthy (extractors transcribe manifests; they do not invent dependencies), but absent edges are not evidence (extractors demonstrably drop them; Sections IV–V). Silence must therefore map to *unknown*, not *false*. The veto remains legitimate only for *evidence-based* unreachability: an excluded scope, or isolation within a graph that the detector classifies as informative.

The measured cost. In our production system (multi-signal CVE prioritization over 18 SBOMs, 2,180 unique CVEs), the closed-world veto silently suppressed 7 of the 8 missed KEV-listed vulnerability instances — all orphan $\times$ multiplicative-zero cases, including CVE-2021-44228 (Log4Shell) whose `log4j-core` sat as an orphan in a container SBOM. KEV recall: 0.600.

The fix and its validation. We introduced (i) an *unknown* reachability level (factor 0.5) assigned to orphans *only* when a degeneracy detector (orphan ratio > 0.5) flags the graph as uninformative, and (ii) an evidence floor that keeps *uncertain* (never evidence-based) unreachability from discounting KEV-listed CVEs. Because the evaluation metric is KEV recall, component (ii) would raise it partly by construction; all headline figures are therefore measured with the KEV flag removed from scoring, so the floor never activates. This does not blind the measurement to the catalogue: EPSS, which is retained, itself encodes KEV membership, and the pipeline's exploitation-status field is set from it. Both arms share that leakage, so the *change* in recall is attributable to the open-world semantics (i), while the levels are operational figures rather than KEV-blind recall. Controlled offline re-scoring (frozen snapshot; KEV ground truth of 20 instances across SBOMs, 17 unique CVEs): recall without the KEV flag 0.600 (12/20) $\rightarrow$ 0.950 (19/20) with flooding guardrail intact ($12.1\% < 15\%$ volume increase). Live end-to-end run (full pipeline, NVD/OSV/OpenCTI/MISP, 4,273 CVEs $\rightarrow$ 251 actionable, 94.1% reduction; 23 KEV instances in this later snapshot): recall without the KEV flag 0.957 (22/23). With the KEV signal restored, the full system reaches recall 1.000 (23/23), an operational figure we report for completeness rather than as evidence, since the floor guarantees part of it by design.

We report this as a directional effect with a documented mechanism rather than a significance test. The ground-truth KEV set is small, so Wilson 95% intervals on the offline measurement are wide and overlapping (0.600: $[0.39, 0.78]$; 0.950: $[0.76, 0.99]$); the claim rests on the identified causal path (every recovered CVE was an orphan the closed-world veto had zeroed) and on the guardrail showing the recovery did not come from indiscriminate up-scoring, rather than on interval separation. Small-n KEV ground truth is an explicit limitation.

Future work. Two experiments extend this result and are in progress. First, *generalization*: replaying the open-world scoring on a stratified sample of Wild SBOMs outside our testbed (degenerate vs. connected) will test whether the recall recovery holds off our own images. Second, the *symmetric question*: measuring how much the reachability veto contributes in the *connected* regime, where the graph is informative and the veto should legitimately prune, against a connected-registry baseline. Together the two experiments bound the semantics from both sides.

The unused escape hatch. CycloneDX `compositions` lets a producer state that the declared graph is incomplete [8]; consumers could route semantics on it. In the wild we find 0.10% usage (59 of 61,691 CycloneDX documents, most of them declaring a mixture that includes `unknown`). Producers do not declare incompleteness because no specification requires them to, which leaves consumers without a machine-readable signal to route semantics on; until that changes, the open-world reading is the only safe default.

VII. IMPLICATIONS

For producers and toolmakers. The regime an SBOM lands in is predicted by the generating tool and its configuration (Table II), and the fix is often already available: resolving

against lockfiles instead of manifests moves an ecosystem from 38.8% degenerate (`pypi`) to about 1% (`composer`). Where edges genuinely cannot be recovered, emitting a one-line `compositions` declaration would convert silent incompleteness into machine-readable uncertainty at negligible cost; today that signal exists in 0.10% of CycloneDX documents.

For specifications and quality gates. NTIA's dependency-relationships requirement is unmet by 52.9% of published SBOMs (42.3% without the generation harness). Field-oriented quality scores respond to the missing block outside that harness (median sbomqs 5.7 for NO_EDGES vs. 6.2 for connected) but not inside it. Quality frameworks should score the *graph* itself (presence of an edge block, orphan ratio, a completeness declaration) as a first-class dimension alongside field population.

For consumers. Until the above happens, the safe default is open-world: detect the regime (the orphan-ratio detector is threshold-insensitive thanks to the empty valley), map silence to *unknown* rather than *unreachable*, and reserve the veto for evidence-based cases. Section VI quantifies what this buys in a production pipeline.

VIII. Related Work

SBOM quality at scale. Adherence-gap studies audit fields and standard compliance: 55K SBOMs, inter-tool package-detection consistency as low as 7.8–12.8% [2]; tool comparisons show divergent container results [32], generator-dependent vulnerability assessment in Python [33], and NTIA minimums unmet in practice [34]; standard-level and tool-landscape analyses contrast the SPDX and CycloneDX ecosystems [35], [36], and SBOM distribution itself lacks integrity protection [37]; flat SBOMs are known to inflate false positives downstream [38]. Corpus papers mine SBOMs at scale (Wild SBOMs [5], Maven Central SBOMs [39], SPDX documents on GitHub [40]), and a recent SLR maps the field's questions [41]. One study measures the declared graph itself: Nocera et al. built dependency graphs from 119 SBOMs of 84 projects and found a path from the primary component to any other node in only 20 of 89 CycloneDX documents, although the dependency-relationship field was present in 78 [4]. That is the phenomenon we measure at population scale; we add the structural taxonomy and quantify NTIA field-5 (dependency relationships) compliance population-wide.

Files-vs-metadata gap. Software Dark Matter quantifies security-relevant files invisible to SBOM metadata and filters triage by file reachability [3]. The two axes are orthogonal (undeclared existence vs. declared-but-edgeless); both undermine closed-world consumption, and we position them as complementary halves of the same consumer hazard.

Registry dependency networks. Ecosystem-level topology is well studied: npm/PyPI/CRAN evolution [42], [43], npm's security-relevant small-world structure [25], Maven Central's 1.3M-node network [44], and vulnerability propagation along registry edges [17], [20]. Those graphs are *resolver-complete* reconstructions from registries; the graph a consumer actually receives inside an SBOM artifact had been measured only on a sample of 119 documents [4]. The contrast is stark: registry graphs are connected and scale-free, whereas declared graphs are absent in half the population; outdatedness studies of Docker images [45] suggest the consumer-side artifacts are the ones that lag the most.

Code-level reachability. Call-graph–based SCA (e.g., Eclipse Steady [46]) prunes false positives by proving vulnerable code unreachable, and comparative studies document large inter-tool disagreement in the vulnerabilities SCA tools report [47]. Our trap sits a layer below: in degenerate declared graphs, the component-level graph needed to even seed such analysis is missing, and hidden code-level dependencies [48] further widen the gap. Unsoundness of "no path found" verdicts mirrors known call-graph incompleteness [49].

IX. Artifact Availability

Three artifacts underpin this study: (i) the streaming topology scanner (stdlib + networkx; processes the 5 GB compressed corpus without full decompression, resumable, per-file fsync), (ii) the per-SBOM topology dataset (one row per parseable SBOM, all measures of Section III), and (iii) the 11-image container SBOM corpus. The scanner and the analysis scripts are archived at doi:10.5281/zenodo.21901870 [50] under the MIT licence; the per-document measures for all 78,612 files, the image-scan corpus and the generator taxonomy are archived at doi:10.5281/zenodo.21886189 [51] under CC-BY-4.0. The primary corpus is not redistributed and remains governed by the Wild SBOMs dataset licence [5]. Figures measured on the prioritization system itself (Section VI) can be read but not re-executed, since that system is not distributed. Earlier versions of this preprint did not link these records.

X. Conclusion

Between two fifths and a half of the SBOMs published in the wild declare no dependency graph at all, depending on whether one dominant generation harness is counted; a further tenth declare one that is mostly isolated vertices. Consumers who read these graphs closed-world convert missing data into confident negative verdicts, and measurably lose known-exploited vulnerabilities. The fix is cheap: treat silence as *unknown*, veto only on evidence, and detect when the graph cannot support the inference. Until producers declare completeness and consumers respect it, "no edges" must mean "no verdict."

Acknowledgment

We thank Markovian Protocol for an independent second measurement of this work [26], which identified the producer of the `Github Extractor` documents and the generation harness behind nearly half of the corpus.

Declaration of Generative AI and AI-Assisted Technologies

During the preparation of this work the author used Claude (Anthropic), via the Claude Code CLI (2026), for three purposes: assisting with drafting and language of the manuscript, supporting the literature search, and helping implement the

analysis tooling described in Section III (the streaming scanner and the statistical scripts). Literature identified with AI assistance was verified against primary sources before citation. All experiments, data, and findings are the author's; the author reviewed and edited all content and takes full responsibility for the content of the published article. The generative-AI tool is not, and cannot be, an author. A complete record of the assisted workflow is preserved in the project's version-control history.

REFERENCES

[1] National Telecommunications and Information Administration, "The minimum elements for a software bill of materials (SBOM)," United States Department of Commerce, Tech. Rep., 2021, pursuant to Executive Order 14028.

[2] C. Wang, J. Wu, H. Lyu, X. Ling, T. Luo, Y. Wu, and C. Zhao, "A large scale empirical analysis on the adherence gap between standards and tools in SBOM," *ACM Transactions on Software Engineering and Methodology*, 2026, to appear. arXiv:2601.05622.

[3] A. Reddypalle, D. Roellke, and S. Torres-Arias, "Software dark matter: Gazing at uncharted files to navigate SBOM integrations," 2026, arXiv preprint arXiv:2606.13966.

[4] S. Nocera, S. Romano, M. Di Penta, R. Francese, and G. Scanniello, "On the adoption of software bill of materials in open-source software projects," *Journal of Systems and Software*, vol. 230, p. 112540, 2025, extends the ICSME 2023 mining study, DOI 10.1109/ICSME58846.2023.00016.

[5] L. Soeiro, T. Robert, and S. Zacchiroli, "Wild SBOMs: a large-scale dataset of software bills of materials from public code," in *Proceedings of the 22nd International Conference on Mining Software Repositories (MSR), Data and Tool Showcase*, 2025, pp. 164–168, dataset: https://doi.org/10.5281/zenodo.14250103. arXiv:2503.15021.

[6] B. Livshits, M. Sridharan, Y. Smaragdakis, O. Lhoták, J. N. Amaral, B.-Y. E. Chang, S. Z. Guyer, U. P. Khedker, A. Møller, and D. Vardoulakis, "In defense of soundiness: A manifesto," *Communications of the ACM*, vol. 58, no. 2, pp. 44–46, 2015.

[7] R. Reiter, "On closed world data bases," in *Logic and Data Bases*. Plenum Press, 1978, pp. 55–76.

[8] OWASP Foundation, "CycloneDX bill of materials specification, version 1.6 — compositions," https://cyclonedx.org/use-cases/compositions-dependencies/, 2024.

[9] The White House, "Executive Order 14028: Improving the nation's cybersecurity," Federal Register 86 FR 26633, 2021.

[10] European Parliament and Council, "Regulation (EU) 2024/2847 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act)," 2024, Official Journal of the European Union, OJ L, 2024/2847. SBOM requirement: Annex I, Part II. ELI: http://data.europa.eu/eli/reg/2024/2847/oj.

[11] CISA, "Framing software component transparency: Establishing a common software bill of materials (SBOM)," Cybersecurity and Infrastructure Security Agency, Tech. Rep., 2024, Third Edition.

[12] A. Tolay, "Automated SBOM-driven vulnerability triage for IoT firmware: A lightweight pipeline for risk prioritization," 2026, arXiv preprint arXiv:2601.01308.

[13] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, "Exploit prediction scoring system (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, 2021.

[14] V. Koscinski, M. Nelson, A. Okutan, R. Falso, and M. Mirakhorli, "Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems," 2025, arXiv preprint arXiv:2508.13644.

[15] R. Parla, "Efficacy of EPSS in high severity CVEs found in KEV," 2024, arXiv preprint arXiv:2411.02618.

[16] L. Baird and A. Moin, "Towards predicting multi-vulnerability attack chains in software supply chains from software bill of materials graphs," in *Proceedings of the ACM International Conference on the Foundations of Software Engineering (FSE), Ideas, Visions and Reflections track*, 2026, arXiv preprint arXiv:2604.04977.

[17] E. Ul Haq, S. Wang, and R. S. Allison, "The ripple effect of vulnerabilities in Maven Central: Prevalence, propagation, and mitigation challenges," 2025, arXiv preprint arXiv:2504.04175.

[18] P. Przymus, M. Fejzer, J. Narębski, K. Rykaczewski, and K. Stencel, "Out of sight, still at risk: The lifecycle of transitive vulnerabilities in Maven," 2025, arXiv preprint arXiv:2504.04803.

[19] C. Yang-Smith and A. Abdellatif, "Tracing vulnerabilities in Maven: A study of CVE lifecycles and dependency networks," 2025, arXiv preprint arXiv:2502.04621.

[20] B. Ruan, Z. Lin, J. Liu, C. Zhang, K. Ji, and Z. Liang, "Propagation-based vulnerability impact assessment for software supply chains," 2025, arXiv preprint arXiv:2506.01342.

[21] I. Pashchenko, H. Plate, S. E. Ponta, A. Sabetta, and F. Massacci, "Vulnerable open source dependencies: Counting those that matter," in *ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, 2018, pp. 1–10.

[22] ——, "Vuln4Real: A methodology for counting actually vulnerable dependencies," *IEEE Transactions on Software Engineering*, vol. 48, no. 5, pp. 1592–1609, 2022.

[23] M. Ohm, H. Plate, A. Sykosch, and M. Meier, "Backstabber's knife collection: A review of open source software supply chain attacks," in *Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA)*, ser. LNCS, vol. 12223, 2020.

[24] P. Ladisa, H. Plate, M. Martinez, and O. Barais, "SoK: Taxonomy of attacks on open-source software supply chains," in *IEEE Symposium on Security and Privacy (S&P)*, 2023, pp. 1509–1526, arXiv:2204.04008.

[25] M. Zimmermann, C.-A. Staicu, C. Tenny, and M. Pradel, "Small world with high risks: A study of security threats in the npm ecosystem," in *28th USENIX Security Symposium*, 2019, arXiv:1902.09217.

[26] Markovian Protocol, "SM-003: Wild SBOMs was billed as the work of many developers. Nearly half came from one robot," Second measurement, Zenodo, doi:10.5281/zenodo.23123301, 2026. [Online]. Available: https://markovianprotocol.com/measurements/sm-003.html

[27] Anchore, Inc., "Syft: CLI tool and library for generating a software bill of materials from container images and filesystems," https://github.com/anchore/syft, 2024, version 1.42, accessed 2026-07.

[28] Interlynk, "sbomqs: Quality metrics for SBOMs," https://github.com/interlynk-io/sbomqs, 2024, accessed 2026-07.

[29] R. Shu, X. Gu, and W. Enck, "A study of security vulnerabilities on Docker Hub," in *ACM Conference on Data and Application Security and Privacy (CODASPY)*, 2017, pp. 269–280.

[30] A. Zerouali, T. Mens, G. Robles, and J. M. Gonzalez-Barahona, "On the relation between outdated docker containers, severity vulnerabilities, and bugs," in *IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER)*, 2019, pp. 491–501.

[31] U. Brandes, "A faster algorithm for betweenness centrality," *Journal of Mathematical Sociology*, vol. 25, no. 2, pp. 163–177, 2001.

[32] J. Bufalino, M. Di Francesco, A. Blaise, and S. Secci, "SBOMproof: Beyond alleged SBOM compliance for supply chain security of container images," 2025, arXiv preprint arXiv:2510.05798.

[33] G. Benedetti, S. Cofano, A. Brighente, and M. Conti, "The impact of SBOM generators on vulnerability assessment in Python: A comparison and a novel approach," 2024, arXiv preprint arXiv:2409.06390.

[34] A. Halbritter and D. Merli, "Accuracy evaluation of SBOM tools for web applications and system-level software," in *Proceedings of the 19th International Conference on Availability, Reliability and Security (ARES)*, 2024, pp. 1–9.

[35] Z. Zhao, A. A. Bangash, T. Ge, A. Singh, Z. Wang, and B. Adams, "The state of the SBOM tool ecosystems: A comparative analysis of SPDX and CycloneDX," 2025, arXiv preprint arXiv:2512.21781.

[36] M. Mirakhorli, D. Garcia, S. Dillon, K. Laporte, M. Morrison, H. Lu, V. Koscinski, and C. Enoch, "A landscape study of open source and proprietary tools for software bill of materials (SBOM)," 2024, arXiv preprint arXiv:2402.11151.

[37] C. Ozkan, X. Zou, and D. Singelee, "Supply chain insecurity: The lack of integrity protection in SBOM solutions," 2024, arXiv preprint arXiv:2412.05138.

[38] L. Zhou, M. Dacier, and C. Konstantinou, "A reality check on SBOM-based vulnerability management: An empirical study and a path forward," 2025, arXiv preprint arXiv:2511.20313.

[39] Y. Gamage, N. Gonzalez Fernandez, M. Monperrus, and B. Baudry, "Software bills of materials in Maven Central," in *Proceedings of the 22nd International Conference on Mining Software Repositories (MSR)*, 2025, arXiv:2501.13832.

[40] A. Chaora, "SBOM dataset from 100 000+ public GitHub repositories," Zenodo, 2025.

[41] E. O'Donoghue, Y. Hastings, E. Ortiz, and A. R. Manzi Muneza, "Software bill of materials in software supply chain security: A systematic literature review," 2025, arXiv preprint arXiv:2506.03507.
[42] A. Decan, T. Mens, and P. Grosjean, "An empirical comparison of dependency network evolution in seven software packaging ecosystems," *Empirical Software Engineering*, vol. 24, no. 1, pp. 381–416, 2019.
[43] R. Kikas, G. Gousios, M. Dumas, and D. Pfahl, "Structure and evolution of package dependency networks," in *Proceedings of the 14th International Conference on Mining Software Repositories (MSR)*, 2017, pp. 102–112.
[44] D. Ogenrwot, J. Businge, and S. Arifuzzaman, "Structural and connectivity patterns in the Maven Central dependency network," 2025, arXiv preprint arXiv:2508.13819.
[45] A. Zerouali, V. Cosentino, T. Mens, G. Robles, and J. M. Gonzalez-Barahona, "On the impact of outdated and vulnerable JavaScript packages in Docker images," in *IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER)*, 2019, pp. 619–623.
[46] S. E. Ponta, H. Plate, and A. Sabetta, "Beyond metadata: Code-centric and usage-based analysis of known vulnerabilities in open-source software," in *Proceedings of the IEEE International Conference on Software Maintenance and Evolution (ICSME)*, 2018, pp. 449–460, Eclipse Steady.
[47] N. Imtiaz, S. Thorn, and L. Williams, "A comparative study of vulnerability reporting by software composition analysis tools," in *Proceedings of the 15th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, 2021, pp. 1–11, arXiv preprint arXiv:2108.12078.
[48] S. Rasheed, M. McPhee, L. Patterson, S. MacDonell, and J. Dietrich, "Hidden dependencies and component variants in SBOM-based software composition analysis," 2026, arXiv preprint arXiv:2604.21278.
[49] M. Reif, F. Kübler, M. Eichberg, D. Helm, and M. Mezini, "Judge: Identifying, understanding, and evaluating sources of unsoundness in call graphs," in *Proceedings of the 28th ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*, 2019, pp. 251–261.
[50] A. Zięba-Kozarzewski, "Streaming SBOM topology scanner and analysis pipeline," 2026, Software, v1.0.0, MIT licence.
[51] ——, "Declared dependency topology of 78,612 real-world SBOMs: full per-document dataset and analysis outputs," 2026, dataset. Derived from Wild SBOMs (doi:10.5281/zenodo.14250103), CC-BY-4.0.